Roteiro 6 — Identity, autenticação e autorização

Disciplina: Desenvolvimento Web com .NET — UNIP. **Fonte:** Roteiros.pdf, páginas 18–20.
Consolidação: 29/10/2026.

Objetivo, introdução e ferramentas

Autenticar contas e proteger operações no servidor e na SPA. A solução utiliza ASP.NET Core Identity sobre o contexto EF Core, roles, claims, cookies, antiforgery e contexto React de sessão. A migration `IdentityUsuarios` incorpora a persistência das contas à solução cumulativa.

Escolha do esquema

Os clientes previstos são navegadores usando MVC e uma SPA que pode ser publicada na mesma aplicação em `/app/`. Não há necessidade estabelecida de clientes de terceiros ou autorização federada. Portanto, cookie protegido é o esquema adotado. Bearer proprietário do Identity e JWT emitido por solução OAuth/OIDC seriam avaliados se surgissem outros clientes/origens; não foi criado um emissor JWT adicional para este domínio.

O cookie possui `HttpOnly`, `Secure` e `SameSite=Lax`, expiração de 30 minutos e renovação deslizante. Antiforgery protege escritas, inclusive login/logout da API. O React obtém token em `/api/auth/csrf`, envia `X-CSRF-TOKEN` e renova o token após mudança de identidade. Contas exigem senha de pelo menos 12 caracteres, número, maiúscula, minúscula e símbolo; cinco falhas provocam bloqueio de cinco minutos.

Seed e funcionalidades

`SeedData` recebe contas e senhas por configuração externa. Cria roles idempotentemente, não redefine a senha de conta existente e atribui ao administrador a claim `tarefas:editar-outra-equipe=true`. Exemplos de tarefas são opcionais. O servidor atribui proprietário e instante de criação.

MVC utiliza `ContaController` e formulário antiforgery. A API expõe login/logout/me/csrf. `AuthContext` restaura a sessão, mantém o estado React e protege rotas; o login preserva uma URL de retorno local. A interface oculta operações incompatíveis com a conta. Os serviços validam as permissões novamente ao executar chamadas diretas.

Matriz de autorização e respostas

Cenário	Resultado esperado
Anônimo consulta tarefa pública	200
Anônimo consulta sessão ou tenta escrita protegida	401

Leitura de privada por anônimo/outra equipe sem acesso	404, preservando a existência privada
Usuário lê tarefa privada de sua equipe	200
Usuário cria para sua equipe	201
Usuário cria para outra equipe	403
Membro da equipe/proprietário edita com versão atual	200
Outra equipe edita sem claim específica	403
Conta com claim edita entre equipes	Permitido conforme recurso/versão; claim não concede leitura privada automaticamente
Usuário comum exclui	403
Administrador exclui com versão atual	204
Escrita com cookie sem token antiforgery	400
Escrita com versão obsoleta	409

O perfil Administrador concede leitura privada e exclusão; sua permissão de edição entre equipes é atribuída pela claim no seed. Listagens, totais e painéis aplicam o mesmo escopo de visibilidade. A comparação EF/ADO também deve respeitar esse escopo.

Aprimoramentos

Há auditoria de login com resultado e identificador, sem credenciais. A política por proprietário/equipe e os testes de integração de autorização complementam o controle por role. Mudanças futuras de permissões só poderão ser declaradas auditadas se houver um fluxo real que as altere e registre o evento; não se presume uma interface administrativa inexistente.

Testes, evidências e conclusão

`ApiTests` exercita sessão, login/logout, privacidade, CSRF e perfis com requisições fora da SPA. `SqlIntegrationTests` verifica permissões e seed no banco exclusivo. `auth.test.tsx` cobre restauração e proteção de rotas no frontend. Os resultados efetivos estão em STATUS_DE_EXECUCAO.md, com referência aos TRX/logs reais.

Além das suítes, o cliente TypeScript gerado executou um fluxo HTTPS real: CSRF 200, login 200, renovação CSRF 200, POST de tarefa 201, GET do detalhe 200 e logout 204. A evidência `frontend-cliente-autenticado.txt` contém somente operações/status/identificadores sintéticos, sem cookies, senha ou token. A criação desse fluxo também originou a evidência real de métrica/span do roteiro 7.

Uma suíte ignorada por falta de conexão não aprova autenticação. A atividade permanece parcial enquanto faltar qualquer verificação obrigatória da matriz, mesmo que os atributos de autorização e os componentes React estejam presentes.